



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-104286 Fortinet FortiMail Path Traversal Exploitation Priority Daily Update

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-10-04
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-104286 Fortinet FortiMail Path Traversal Exploitation Priority Daily Update - CVE / Vulnerability Threat Intelligence Report

Published: 2026-10-04 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Metadata
3. Source Review and Confidence
4. Threat / Vulnerability Details
5. Attack Scenarios
6. Affected Products, Sectors, and Exposure
7. Detection Engineering
 - 7.1. Detection Logic Summary
8. Threat Hunting
 - 8.1. Microsoft Defender / KQL Hunt
9. MITRE ATT&CK Mapping
10. Recommended Actions Summary
11. References

CVE-2026-104286 Fortinet FortiMail Path Traversal Exploitation

Priority Daily Update

1. Executive Summary

CISA added CVE-2026-104286, a Fortinet FortiMail path traversal vulnerability, to KEV on 2026-10-01 based on evidence of active exploitation. FortiMail systems are high-value mail-security edge assets, so defenders should prioritize exposure review, patch verification, and retrospective hunting.

Lost Boys Cyber selected this item for the 2026-10-04 daily production run because it has current defender relevance, credible public sourcing, and actionable implications for vulnerability management, threat hunting, detection engineering, or sector risk reduction.

2. Intelligence Metadata

Field	Value
CVE	CVE-2026-104286
Product	Fortinet FortiMail
Daily rank	Top vulnerability 1
Exploitation status	CISA KEV / reported active exploitation
Published date	2026-10-04
CVE	Priority
CVE-2026-104286	Critical

****Daily update note (2026-10-04):**** This source-backed refresh keeps the item in today's coverage because the exposure remains operationally relevant for defenders. Analysts should validate vendor status, current exploitation reporting, and environment-specific telemetry before using any detection or hunt content operationally.

3. Source Review and Confidence

Source	URL	Contribution
CISA Known Exploited Vulnerabilities Catalog	https://www.cisa.gov/known-exploited-vulnerabilities-catalog	Authoritative exploited-vulnerability prioritization source.
CISA alert - CVE-2026-104286 Fortinet FortiMail added to KEV	https://www.cisa.gov/news-events/alerts/2026/10/01/cisa-adds-one-known-exploited-vulnerability-catalog	Source used for current-day defender prioritization.
Fortinet PSIRT advisories	https://www.fortiguard.com/psirt	Source used for current-day defender prioritization.
NVD CVE lookup	https://nvd.nist.gov/vuln/search/results?query=CVE-2026-104286&search_type=all	Source used for current-day defender prioritization.

Confidence: ****high****. This assessment avoids asserting uncorroborated exploit mechanics or victim counts. Where sources are strategic rather than IOC-heavy, the report focuses on control validation, exposure review, and behavior-based hunts.

4. Threat / Vulnerability Details

Public reporting identifies the issue as a Fortinet FortiMail path traversal vulnerability with active exploitation significance. Mail security gateways can expose credentials, quarantined content, routing details, and trusted relay paths; defenders should treat unexplained file access, service-spawned tooling, and outbound transfer from mail-security appliances as high-priority triage signals.

5. Attack Scenarios

Scenario	Description	Defensive Priority
Opportunistic exploitation	Adversaries scan for exposed services, stale software, weak identity controls, or public-facing infrastructure matching the reporting.	Patch and exposure validation within 24-72 hours.
Targeted access	A focused actor uses the issue or campaign tradecraft against high-value organizations, suppliers, or sector-specific operators.	Identity telemetry, EDR coverage, supplier assurance, and incident escalation paths.
Post-compromise expansion	Initial access is followed by credential theft, remote tooling, persistence, data staging, or lateral movement.	Hunt for suspicious child processes, unusual authentication, outbound transfer, and administrative changes.

6. Affected Products, Sectors, and Exposure

Exposure Pattern	Why It Matters	Immediate Check
Internet-facing edge or collaboration systems	High discovery rate and common initial-access path.	Inventory and patch externally reachable assets.
Identity and remote access paths	Enables stealthy follow-on access even after the initial vulnerability or campaign is mitigated.	Review MFA, impossible travel, new tokens, and privileged group changes.
Supplier or managed service connectivity	Extends risk to aviation, aerospace, government, and enterprise environments via trusted links.	Request supplier attestations and review third-party access logs.
Endpoint execution and scripting	Post-exploitation behaviors frequently appear as shells, script interpreters, archive tools, or remote management utilities.	Deploy behavior-based EDR analytics and triage recent hits.

7. Detection Engineering

7.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Edge service spawning shell, script, or archive tooling	EDR process telemetry	Detect exploitation follow-on actions.
New outbound connections from server or admin tier	Network/EDR telemetry	Identify payload retrieval, C2, or data staging.
Abnormal identity activity following exposure	Entra ID/Okta/VPN logs	Catch token theft, new MFA methods, impossible travel, or admin role changes.

New persistence or remote access tooling	EDR, Windows events, package manager logs	Identify durable footholds and hands-on-keyboard activity.
<pre> title: LBC Daily Report Suspicious Server Follow-On Activity - LBC-VTI-2026-1388 status: experimental logsource: product: windows category: process_creation detection: parent_service: ParentImage contains: - "\w3wp.exe" - "\httpd.exe" - "\nginx.exe" - "\tomcat" - "\java.exe" child_tools: Image endswith: - "\cmd.exe" - "\powershell.exe" - "\pwsh.exe" - "\rundll32.exe" - "\certutil.exe" - "\curl.exe" - "\wget.exe" - "\7z.exe" condition: parent_service and child_tools fields: - UtcTime - Computer - ParentImage - Image - CommandLine falsepositives: - Administrative scripts; validate change ticket and parent service context. level: high </pre>		

8. Threat Hunting

8.1. Microsoft Defender / KQL Hunt

```

let lookback = 14d;
DeviceProcessEvents
| where Timestamp > ago(lookback)
| where InitiatingProcessFileName in~ ("w3wp.exe","httpd.exe","nginx.exe","tomcat.exe","java.exe")
| where FileName in~
("cmd.exe","powershell.exe","pwsh.exe","rundll32.exe","certutil.exe","curl.exe","wget.exe","7z.exe","ba
sh.exe","sh")
| project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine,
InitiatingProcessCommandLine, AccountName
| order by Timestamp desc

```

Purpose: surface suspicious command execution from server or edge-service parents that may follow exploitation or campaign delivery.

```

let lookback = 14d;
DeviceNetworkEvents
| where Timestamp > ago(lookback)
| where InitiatingProcessFileName in~
("w3wp.exe","httpd.exe","nginx.exe","java.exe","powershell.exe","cmd.exe","curl.exe","wget.exe")
| summarize Connections=count(), RemoteIPs=dcount(RemoteIP), SampleRemote=make_set(RemoteUrl, 10) by
DeviceName, InitiatingProcessFileName, bin(Timestamp, 1h)
| where Connections > 5 or RemoteIPs > 3
| order by Timestamp desc

```

Purpose: identify unusual outbound activity from infrastructure that should not normally initiate broad external sessions.

9. MITRE ATT&CK Mapping

Technique	Rationale
T1190 Exploit Public-Facing Application	Public-facing service exploitation remains a primary risk path for vulnerability-driven items.
T1059 Command and Scripting Interpreter	Post-exploitation and malware delivery frequently rely on shell or script execution.
T1105 Ingress Tool Transfer	Payload retrieval and tool staging are common after initial access.
T1078 Valid Accounts	Campaigns often convert initial access into durable account or token access.

10. Recommended Actions Summary

Priority	Owner	Action
Critical	Vulnerability Management	Confirm exposure and remediation status for affected products, services, and suppliers.
High	SOC / Detection Engineering	Deploy the provided process and network hunts; tune for known administrative tooling.
High	Identity / IAM	Review recent MFA, token, privileged role, and risky sign-in events for exposed environments.
Medium	Third-Party Risk	Request attestations from suppliers and managed service providers with relevant access.
Medium	Incident Response	Preserve logs for at least 30 days and open cases for unexplained service-spawned tooling.

11. References

- [1] CISA Known Exploited Vulnerabilities Catalog: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [2] CISA alert - CVE-2026-104286 Fortinet FortiMail added to KEV: <https://www.cisa.gov/news-events/alerts/2026/10/01/cisa-adds-one-known-exploited-vulnerability-catalog>
- [3] Fortinet PSIRT advisories: <https://www.fortiguard.com/psirt>
- [4] NVD CVE lookup: https://nvd.nist.gov/vuln/search/results?query=CVE-2026-104286&search_type=all